

DATABEHANDLERAVTALE

for Myntland

Behandling av personopplysninger på vegne av kommune/skoleeier

Mellom

Behandlingsansvarlig (Kunden)	[KOMMUNENS NAVN] Org.nr.: [ORGNR] Adresse: [ADRESSE] Kontaktperson: [NAVN, E-POST]
Databehandler (Leverandør)	[SELSKAPSNAVN] Org.nr.: [ORGNR] Adresse: [ADRESSE] Kontakt: post@myntland.no

Avtaledato: _____

1. Avtalens formål og omfang

Denne databehandleravtalen («Avtalen») regulerer Databehandlerens behandling av personopplysninger på vegne av Behandlingsansvarlig i forbindelse med levering av tjenesten Myntland («Tjenesten»).

Myntland er en pedagogisk plattform for økonomilæring rettet mot grunnskolen (1.–7. trinn). Tjenesten lar lærere drive et klasseromsbasert økonomispill der elever får virtuelle penger, gjør transaksjoner, sparer og opplever ulike økonomiske hendelser.

Avtalen skal sikre at personopplysninger behandles i samsvar med personopplysningsloven og EUs personvernforordning (GDPR), heretter samlet omtalt som «Personvernregelverket».

Avtalen består av denne avtaleteksten samt følgende bilag som utgjør en integrert del av Avtalen:

- Bilag A – Behandlingens art, formål og omfang
- Bilag B – Underleverandører
- Bilag C – Sikkerhetstiltak

2. Definisjoner

Begrepene «personopplysninger», «behandling», «behandlingsansvarlig», «databehandler», «den registrerte» og «brudd på personopplysningssikkerheten» har samme betydning som i GDPR artikkel 4.

Med «den registrerte» menes i hovedsak elever og lærere ved skoler hos Behandlingsansvarlig som benytter Myntland.

3. Behandlingsansvarliges plikter

Behandlingsansvarlig er ansvarlig for at behandlingen av personopplysninger skjer i overensstemmelse med Personvernregelverket og skal særlig sørge for at:

1. Behandlingen er formålsbestemt og basert på et gyldig rettsgrunnlag.
2. De registrerte (eller deres foresatte for mindreårige) har mottatt nødvendig informasjon om behandlingen.
3. Det er gjennomført tilstrekkelige risikovurderinger, herunder eventuell vurdering av personvernkonsekvenser (DPIA) der det er påkrevd.
4. Det foreligger nødvendige instruksjoner til Databehandleren.

Behandlingsansvarlig har rett til å gi utfyllende instruksjoner til Databehandleren om hvordan personopplysningene skal behandles. Slike instruksjoner skal være skriftlige og kan ikke gå ut over det som er regulert i Avtalen uten at det inngås tilleggssavtale.

4. Databehandlerens plikter

4.1 Generelt

Databehandleren skal kun behandle personopplysninger i tråd med Avtalen og dokumenterte instruks fra Behandlingsansvarlig. Databehandleren skal ikke behandle personopplysninger til egne formål.

Dersom Databehandleren er av den oppfatning at en instruks er i strid med Personvernregelverket, skal Databehandleren umiddelbart varsle Behandlingsansvarlig.

4.2 Konfidensialitet

Databehandleren skal sikre at personer som er autorisert til å behandle personopplysningene har forpliktet seg til konfidensialitet eller er underlagt en passende lovbestemt taushetsplikt.

4.3 Sikkerhet

Databehandleren skal gjennomføre egnede tekniske og organisatoriske tiltak for å sikre et sikkerhetsnivå som er tilpasset risikoen, jf. GDPR artikkel 32. De konkrete sikkerhetstiltakene er beskrevet i Bilag C.

4.4 Bistand til Behandlingsansvarlig

Databehandleren skal, så langt det er mulig, bistå Behandlingsansvarlig med:

- Å besvare henvendelser fra de registrerte om utøvelse av deres rettigheter (innsyn, retting, sletting, dataportabilitet mv.).
- Å overholde forpliktelsene i GDPR artikkel 32–36 (sikkerhet, avviksvarsling, DPIA og forhåndsdrøfting).

4.5 Avviksvarsling

Ved brudd på personopplysningssikkerheten skal Databehandleren varsle Behandlingsansvarlig uten ugrunnet opphold, og senest innen 24 timer etter at bruddet er oppdaget. Varselet skal som minimum inneholde:

- Beskrivelse av bruddets art, omfang og sannsynlige konsekvenser
- Hvilke kategorier og omtrent hvor mange registrerte og opplysninger som er berørt
- Iverksatte og foreslåtte tiltak for å håndtere bruddet
- Kontakthinformatjon for videre dialog

5. Bruk av underleverandører

Behandlingsansvarlig gir Databehandleren generell tillatelse til å benytte underleverandører som angitt i Bilag B. Databehandleren skal informere Behandlingsansvarlig om planlagte endringer i underleverandører senest 30 dager før endringen trer i kraft, slik at Behandlingsansvarlig har anledning til å motsette seg endringen.

Databehandleren skal ved bruk av underleverandører inngå skriftlig avtale som pålegger underleverandøren tilsvarende forpliktelser som følger av denne Avtalen. Databehandleren har det fulle ansvar overfor Behandlingsansvarlig for at underleverandører oppfyller sine forpliktelser.

6. Overføring til tredjeland

Personopplysninger skal som hovedregel behandles innenfor EU/EØS. Dersom personopplysninger overføres til tredjeland, skal slik overføring kun skje på et av grunnlagene som er angitt i GDPR kapittel V, herunder gjennom EU-kommisjonens beslutning om tilstrekkelig beskyttelsesnivå eller EUs standardkontrakter (SCC).

Eventuelle overføringer til tredjeland er angitt i Bilag B.

7. Revisjon og dokumentasjon

Databehandleren skal stille til rådighet all informasjon som er nødvendig for å påvise at forpliktelsene i Avtalen overholdes, og skal muliggjøre og bidra til revisjoner som utføres av Behandlingsansvarlig eller en annen revisor utpekt av Behandlingsansvarlig.

Databehandleren kan oppfylle sin dokumentasjonsplikt ved å fremlegge oppdatert leverandørerklæring og eventuelle relevante sertifiseringer eller revisjonsrapporter. Behandlingsansvarlig kan kreve ytterligere dokumentasjon dersom risikobildet tilsier det.

Behandlingsansvarlig dekker egne kostnader ved revisjon. Databehandleren kan kreve dekket dokumenterte merkostnader ved omfattende revisjoner ut over én gang per år.

8. Sletting og retur av personopplysninger

Når Avtalen opphører, skal Databehandleren etter Behandlingsansvarliges valg slette eller tilbakelevere alle personopplysninger til Behandlingsansvarlig, og slette eksisterende kopier, med mindre lagring kreves av lov.

Sletting skal skje innen 30 dager etter Avtalens opphør. Databehandleren skal skriftlig bekrefte at sletting er gjennomført.

Personopplysninger om elever og lærere som ikke lenger er aktive brukere av Tjenesten (f.eks. ved skolebytte eller endt skoleløp), skal slettes løpende i tråd med rutinene beskrevet i Bilag A.

9. Ansvar og erstatning

Hver av Partene er ansvarlige overfor de registrerte for skade som oppstår som følge av brudd på Personvernregelverket, jf. GDPR artikkel 82.

I forholdet mellom Partene er hver Part ansvarlig for skade som skyldes Partens egne brudd på Avtalen eller Personvernregelverket. En Part som har betalt full erstatning til en registrert, har rett til regress fra den andre Parten i samsvar med Partens andel av ansvaret.

Databehandlerens samlede erstatningsansvar overfor Behandlingsansvarlig er begrenset til [FYLL UT, f.eks. årlig vederlag for Tjenesten / et bestemt beløp], unntatt ved forsett eller grov uaktsomhet, eller ved brudd på taushetsplikten.

10. Varighet og opphør

Avtalen trer i kraft ved signering og gjelder så lenge Databehandleren behandler personopplysninger på vegne av Behandlingsansvarlig.

Dersom en av Partene vesentlig misligholder sine forpliktelser etter Avtalen, kan den andre Parten heve Avtalen med umiddelbar virkning.

11. Lovvalg og vernetting

Avtalen er underlagt norsk rett. Tvister som måtte oppstå skal søkes løst i minnelighet. Dersom enighet ikke oppnås, skal tvisten avgjøres ved Behandlingsansvarliges vernetting.

12. Signatur

For Behandlingsansvarlig	For Databehandler
Sted/dato: _____	Sted/dato: _____
_____ Navn: Stilling:	_____ Navn: Stilling:

Bilag A – Behandlingens art, formål og omfang

A.1 Formål med behandlingen

Behandling av personopplysninger i Myntland har som formål å:

- Tilby elever en pedagogisk plattform for læring om økonomi gjennom et klasseromsbasert spill
- Gi lærere verktøy for å administrere klassens økonomispill, inkludert tildeling av lønn, registrering av transaksjoner, og iverksetting av økonomiske hendelser
- Lagre elevenes saldo, transaksjonshistorikk og spillstatus slik at spillet kan fortsette over tid

A.2 Behandlingens art

Behandlingen omfatter innsamling, registrering, lagring, tilgang, endring og sletting av personopplysninger i forbindelse med bruk av Tjenesten.

A.3 Kategorier av registrerte

- Elever i grunnskolen (1.–7. trinn), typisk i alderen 6–13 år
- Lærere og andre ansatte ved skolen som administrerer Tjenesten

A.4 Kategorier av personopplysninger

Følgende personopplysninger behandles om elever:

- Pseudonym/kallenavn (lærer eller skole velger pseudonym; elevens fulle navn registreres ikke i Tjenesten)
- Klassetilhørighet (klassekode/gruppe)
- PIN-kode for innlogging (lagres ikke i klartekst)
- Spilldata: virtuell saldo, transaksjonshistorikk, hendelser, spareaktivitet

Merk: Tjenesten er utformet for pseudonymisert behandling av elevdata. Dataene som lagres i Tjenesten kan i seg selv ikke identifisere en bestemt elev uten tilleggsinformasjon som finnes hos skolen (koblingen mellom pseudonym og fysisk elev). Dette gir dataminimering i praksis. Behandlingsansvarlig oppfordres til å ikke bruke gjenkjennelige pseudonymer som «Ola Nordmann 5B».

Følgende personopplysninger behandles om lærere:

- Navn
- E-postadresse
- Tilknytning til skole/klasse
- Innloggingsinformasjon

A.5 Særlige kategorier av personopplysninger

Tjenesten er ikke utformet for å behandle særlige kategorier av personopplysninger (sensitive opplysninger) som definert i GDPR artikkel 9, herunder helseopplysninger, religiøs overbevisning eller etnisk opprinnelse. Behandlingsansvarlig skal ikke registrere slike opplysninger i Tjenesten.

A.6 Behandlingens varighet

Personopplysninger behandles så lenge eleven eller læreren er aktiv bruker av Tjenesten ved en skole tilknyttet Behandlingsansvarlig.

Sletterutiner:

- Elevdata slettes innen 30 dager etter at eleven slutter ved skolen eller skolebyttet er gjennomført
- Klassedata slettes ved skoleårets slutt med mindre læreren aktivt velger å videreføre
- Inaktive kontoer (ingen pålogging på 12 måneder) slettes automatisk
- Ved opphør av Avtalen slettes alle data innen 30 dager

Bilag B – Underleverandører

Databehandleren benytter følgende underleverandører for behandling av personopplysninger:

Underleverandør	Tjeneste/funksjon	Lokasjon for behandling	Overføringsgrunnlag
Google Ireland Ltd. / Google LLC	Firebase (databaselagring, autentisering, hosting)	EU/EØS (Firebase region: europe-west)	Behandling skjer innenfor EØS. Eventuell teknisk støtte fra Google LLC dekkes av EU-kommisjonens standardkontrakter (SCC) og Google Cloud Data Processing Addendum.
[FYLL UT – f.eks. domeneleverandør, hostingleverandør hvis annen]	[FYLL UT]	[FYLL UT]	[FYLL UT]

Databehandleren har inngått skriftlig databehandleravtale med Google for bruk av Firebase-tjenestene som regulerer Googles behandling av personopplysninger på vegne av Databehandleren.

Endringer i underleverandører

Endringer i underleverandører varsles Behandlingsansvarlig skriftlig (typisk per e-post til registrert kontaktperson) senest 30 dager før endringen iverksettes. Behandlingsansvarlig kan motsette seg endringen og har i så fall rett til å heve Avtalen dersom Partene ikke blir enige om en alternativ løsning.

Bilag C – Sikkerhetstiltak

Databehandleren har iverksatt følgende tekniske og organisatoriske sikkerhetstiltak for å beskytte personopplysningene, jf. GDPR artikkel 32:

C.1 Tilgangskontroll

- All tilgang til Tjenesten krever autentisering
- Lærere har egne kontoer med passordbeskyttelse
- Elever logger inn med PIN-kode tilknyttet pseudonym/kallenavn (ikke ekte navn)
- [Ved Feide-integrasjon: Pålogging via Feide med skoleeiers eksisterende identitetsforvaltning]
- Tilgang til administrasjonspanel og databaser er begrenset til autoriserte personer hos Databehandler

C.2 Kryptering og overføring

- All kommunikasjon mellom klient og server skjer over HTTPS/TLS
- Personopplysninger lagres i Firebase Realtime Database / Firestore med kryptering i hvile (AES-256)
- PIN-koder lagres ikke i klartekst

C.3 Databasesikkerhet

- Firebase Security Rules begrenser tilgang slik at lærere kun kan lese/skrive data tilhørende egen klasse, og elever kun til egen profil
- Skriverettigheter er strengt begrenset ('\$other: false'-mønster benyttes for å hindre uautoriserte felter)
- Databasekonfigurasjonen revideres regelmessig

C.4 Logging og overvåking

- Sikkerhetshendelser logges i Firebase/Google Cloud-plattformen
- Unormale aktivitetsmønstre kan oppdages og varsles
- Logger oppbevares i samsvar med formålet og slettes når de ikke lenger er nødvendige

C.5 Backup og gjenoppretting

- Daglig automatisk sikkerhetskopi via Firebase
- Sikkerhetskopier oppbevares i EU/EØS
- Rutiner for gjenoppretting er testet

C.6 Innebygd personvern (Privacy by Design)

- Tjenesten er utformet for pseudonymisert behandling — elevenes fulle navn registreres ikke i Tjenesten
- Tjenesten samler inn kun personopplysninger som er nødvendige for formålet (dataminimering)

- Det benyttes ingen tredjeparts sporings- eller analyseverktøy som identifiserer enkeltbrukere
- Tjenesten benytter ingen reklame eller markedsføring

C.7 Organisatoriske tiltak

- Personer med tilgang til personopplysninger er underlagt taushetsplikt
- Rutiner for håndtering av sikkerhetsbrudd er etablert
- Databehandler gjennomfører jevnlig egen risikovurdering av Tjenesten

C.8 Sletting

- Sletterutiner som beskrevet i Bilag A pkt. A.6
- Sletting skjer både fra primærdatabase og sikkerhetskopier (sikkerhetskopier overskrives etter maksimalt [FYLL UT, f.eks. 30] dager)